

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-23 09:00 WIB

Top 5 Highlights

- BigCommerce merchants impacted by third-party app data breach
- VA criticizes Baylor Genetics for delayed notification after data breach
- TASK#STOMP campaign uses PowerShell backdoor for data theft
- BYD Shark 6 remotely hacked, exposing vehicle controls and cabin audio
- Microsoft Entra ID to retire SMS sign-in in 2027

Threat Intelligence (10)

01. TASK#STOMP campaign uses PowerShell backdoor for data theft

The TASK#STOMP campaign begins with an encoded Visual Basic Script (VBScript) executed by wscript.exe, with the initial access vector likely being phishing or social engineering.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/brief/taskstomp-campaign-uses-powershell-backdoor-for-data-theft>

02. New Exvicy malware-as-a-service framework copies rival's code

Exvicy operates as a ClickFix framework, distributing malware through compromised WordPress websites, according to Sekoia's Threat Detection & Research team.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/new-exvicy-malware-as-a-service-framework-copies-rivals-code>

03. Windows CLOSEDQUORUM malware uses AI models to autonomously select post-compromise actions

'first' publicly documented Windows implant to use LLMs for C2

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/09/22/windows-closedquorum-malware-uses-ai-models-to-autonomously-select-post-compromise-actions/5298435>

04. Microsoft Disrupts EvilTokens Device Code Phishing Service

Microsoft seized 50 websites and disabled more than 150 domains as part of a coordinated disruption effort against a phishing-as-a-service platform targeting Microsoft 365 accounts.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.darkreading.com/identity-access-management-security/microsoft-disrupts-eviltokens-device-code-phishing-service>

05. The Truth about GET and HTTP Standards, (Tue, Sep 22nd)

On Friday, Xavier talked about the newly introduced HTTP Query method. This new method was introduced to allow "GET" requests that include a body. The main reason for this was that GET requests typically do not contain a body. But what if they do?

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33358>

06. CFP No cON Name 2k26 - Palma, Mallorca - Spain

Posted by Jose Nicolas Castellano on Sep 22 No cON Name 2026 - Palma, Mallorca - Balearic Islands ***** Call For Papers *****

***** <https://www.noconname.org/call-for-papers/> Exact place not disclosed until a few weeks before due celebration. *
INTRODUCTIONfulldisclosure () seclists org Th...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Sep/48>

07. APPLE-SA-09-14-2026-10 Xcode 27

Posted by Apple Product Security via Fulldisclosure on Sep 22 APPLE-SA-09-14-2026-10 Xcode 27 Xcode 27 addresses the following issues. Information about the security content is also available at <https://support.apple.com/149040...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Sep/62>

08. APPLE-SA-09-14-2026-9 Safari 27

Posted by Apple Product Security via Fulldisclosure on Sep 22 APPLE-SA-09-14-2026-9 Safari 27 Safari 27 addresses the following issues. Information about the security content is also available at <https://support.apple.com/149039...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Sep/61>

09. APPLE-SA-09-14-2026-8 visionOS 27

Posted by Apple Product Security via Fulldisclosure on Sep 22 APPLE-SA-09-14-2026-8 visionOS 27 visionOS 27 addresses the following issues. Information about the security content is also available at <https://support.apple.com/149038...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Sep/60>

10. APPLE-SA-09-14-2026-7 watchOS 27

Posted by Apple Product Security via Fulldisclosure on Sep 22 APPLE-SA-09-14-2026-7 watchOS 27 watchOS 27 addresses the following issues. Information about the security content is also available at <https://support.apple.com/149037...>

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://seclists.org/fulldisclosure/2026/Sep/59>

Latest Vulnerabilities (10)

01. BigCommerce merchants impacted by third-party app data breach

The breach occurred between September 13 and September 17, 2026, when attackers gained access to shopper data via compromised credentials for the Ribon and Ribon 1.5 applications.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/bigcommerce-merchants-impacted-by-third-party-app-data-breach>

02. BYD Shark 6 remotely hacked, exposing vehicle controls and cabin audio

Cybersecurity researcher Dan Hreszczuk of Fortify Labs found a critical vulnerability in a BYD Shark 6, allowing remote access to vehicle functions.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/byd-shark-6-remotely-hacked-exposing-vehicle-controls-and-cabin-audio>

03. Microsoft Entra ID to retire SMS sign-in in 2027

Microsoft will retire SMS and voice-based sign-in as a first-factor authentication method for Entra ID workforce tenants starting February 1, 2027.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/microsoft-entra-id-to-retire-sms-sign-in-in-2027>

04. Chinese hackers exploit WordPress, Zyxel flaws to steal govt data

A Chinese-speaking threat actor has been exploiting vulnerabilities in ZyXEL GS1900 Smart Managed Switches and WordPress to steal sensitive data from 996 devices and more than 18,500 records stored in backend databases. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/chinese-hackers-exploit-multiple-technologies-to-steal-govt-data/>

05. Code Security Review tool

Posted by E. Kellinis on Sep 22 Karma Pro is an open source code review tool that can assist code reviewers with a multitude of useful tools. Karma Pro is a macOS source-code security scanner (AST base and Heuristics) that statically analyses projects in multiple languages. It's backed by an ML classifier trained on real patches to catch subtle issues. Beyo...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/49>

06. HP Advance / Output Central: unauthenticated SYSTEM RCE and two additional vulnerabilities (CVE-2026-89082/89083/89084)

Posted by Joe via Fulldisclosure on Sep 22 HP Advance / HP Output Central
Unauthenticated SYSTEM RCE, authorization bypass, and arbitrary file write/delete
CVE-2026-89082, CVE-2026-89083, CVE-2026-89084 =====
===== SUMMARY =====
===== Vendor: HP Inc. Pr...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/66>

07. CVE-2026-17613: Penpot cross-team file takeover via import-binfile (unpatched in 2.17.2)

Posted by Louis Sanchez via Fulldisclosure on Sep 22 Posting this as an update rather than a first disclosure. The advisory went public on 2026-08-04 with no vendor fix. Penpot has shipped two releases since then, 2.17.1 and 2.17.2 -- the latter 14 days ago, on 2026-08-27 -- and I re-checked the code this morning: the missing permission check is still missi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/47>

08. CVE-2026-44756: Pre-Auth RCE in SAP EPP Processing (ICM, Web Dispatcher, disp+work)

Posted by Raschin Tavakoli via Fulldisclosure on Sep 22 nullFactor Security Advisory ==
=====

== Title: Pre-Authentication Remote Code Execution in SAP Extended Passport (EPP) processing library Affected Components: ICM, SAP Web Dispatcher, dialog work processes Vulnerability: Stack based Buffer Overflow CVE:...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/65>

09. [Oday-rubbish] TigerGraph Community Edition 4.2.4 Default credentials plus GSQL TO_CSV arbitrary file write to SSH code execution (9.8)

Posted by disclosure via Fulldisclosure on Sep 22 Oday Rubbish Research Team is publicly disclosing a vulnerability in TigerGraph Community Edition 4.2.4. Type: Default credentials plus GSQL TO_CSV arbitrary file write to SSH code execution (CWE-798) CVSS: 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H) Impact: command execution as the tigergraph service user (ui...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/64>

10. [Oday-rubbish] Teltonika RutOS 00.07.06.21 Authenticated ipsec.lua logread command injection with reflected output (8.8)

Posted by disclosure via Fulldisclosure on Sep 22 0day Rubbish Research Team is publicly disclosing a vulnerability in Teltonika RutOS 00.07.06.21. Type: Authenticated ipsec.lua logread command injection with reflected output (CWE-78) CVSS: 8.8 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H) Impact: root command execution on the router, with command output reflected...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/63>

Data Breach & Cybercrime (10)

01. VA criticizes Baylor Genetics for delayed notification after data breach

The cybersecurity incident at Baylor Genetics, occurring around June 15, resulted in unauthorized access to sensitive information of 30,263 veterans.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/va-criticizes-baylor-genetics-for-delayed-notification-after-data-breach>

02. Sweden fines Miljödata \$183,000 over breach affecting 2.2 million

Sweden's data privacy regulator, IMY, has imposed a \$183,000 (SEK 1.8 million) fine on IT systems provider Miljödata for inadequate security measures leading to a breach in August 2025 affecting 2.2 million people. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/sweden-fines-milj-data-183-000-over-breach-affecting-22-million/>

03. Microsoft's EvilTokens takedown sheds light on state of AI-powered cybercrime

Microsoft has hailed its success in disrupting EvilTokens , an AI-powered a phishing-as-a-service (PhaaS) platform linked to more than 12,000 compromised Microsoft 365 inboxes across more than 10,000 organizations worldwide. Since February 2026, EvilTokens has offered a subscription platform combining account compromise, mailbox analysis, target selection,...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoononline.com/article/4225175/microsofts-eviltokens-takedown-sheds-light-on-state-of-ai-powered-cybercrime.html>

04. ShinyHunters claims FBI hack, data theft in PeopleSoft zero-day breach

The ShinyHunters extortion gang claims it breached FBI systems using a new Oracle PeopleSoft zero-day vulnerability, gaining access to internal services and stealing sensitive data on employees and job applicants. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/shinyhunters-claims-fbi-hack-data-theft-in-peoplesoft-zero-day-breach/>

05. Shai-Hulud Attack Nips Cyber-Firm CrowdSec's GitHub Data

Threat actors stole 170 private repositories using an OAuth token stolen from a former employee's computer through the TanStack npm supply chain attack.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/shai-hulud-attack-cyber-firm-crowdsec-github-data>

06. UK cops arrest 2 EvilTokens suspects, Microsoft seizes 50 phishing kit websites

Used by crims to compromise 12K+ email inboxes across 10K+ global orgs

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/09/22/uk-cops-arrest-2-eviltokens-suspects-microsoft-seizes-50-phishing-kit-websites/5298317>

07. Webinar tomorrow: Inside real-world Google Workspace breaches

Tomorrow's webinar examines real Google Workspace breaches involving social engineering and malicious OAuth applications, from initial access through the critical first hours of incident response. Learn which security controls and response decisions can make the greatest difference. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/webinar-tomorrow-inside-real-world-google-workspace-breaches/>

08. AI Drives Surge in Bot and API Threats

Akamai report warns of increase in bot traffic, API threats, chatbot leaks and other AI-related threats

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/ai-drives-surge-in-bot-and-api/>

09. [+24h Old] Scammers use genuine Google sign-ins to sell costly, unverified AI subscriptions

Scammers are using a \$249 website toolkit to sell unverified AI subscriptions worth up to \$2,000 a year, and a genuine Google sign-in screen is what makes the sites convincing. Malwarebytes found more than 100 websites built this way, all tied to the same toolkit and closely related developer details. The network includes sites that copy the names of existi...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/22/fake-ai-subscription-sites-google-sign-in/>

10. [+24h Old] Gemini broke into 3 companies, but Google kept it quiet because 'no damage was done'

A Google Gemini AI agent broke into three companies in May, guessing the credentials for one and discovering the credentials for the second two in a public repository, Google confirmed on Monday. But the more interesting background to the story, which was broken by The Wall Street Journal on Friday, is that the May incident stemmed from a series of cybersec...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoonline.com/article/4224570/gemini-broke-into-3-companies-but-google-kept-it-quiet-because-no-damage-was-done.html>